LAPORAN AUDIT KEAMANAN WEBSITE

Spencer Web Security Audit Tool

Target Website	polmed.ac.id
URL Lengkap	https://polmed.ac.id
Tanggal Audit	21 May 2026, 11:26:57 WIB
Metode	OWASP Top 10 + CVSS Scoring
Tool	SpencerWeb v2.0
Durasi Scan	219.48 detik

SECURITY GRADE: F **SKOR: 0/100**

1. RINGKASAN EKSEKUTIF

Audit keamanan website **polmed.ac.id** telah dilakukan pada tanggal **21 May 2026, 11:26:57 WIB** menggunakan Spencer Web Security Audit Tool. Audit ini menggunakan metodologi OWASP Top 10 dengan sistem penilaian risiko CVSS yang disederhanakan menjadi grade A-F.

Berdasarkan 92 pengecekan keamanan yang dilakukan, sistem mendapat grade **F** dengan skor **0/100**. Ditemukan total **55 kerentanan** yang terdiri dari:

Severity	Jumlah	Dampak
CRITICAL	0	Risiko tertinggi, harus segera diperbaiki
HIGH	14	Risiko tinggi, perbaiki dalam waktu dekat
MEDIUM	5	Risiko sedang, jadwalkan perbaikan
LOW	36	Risiko rendah, perbaikan opsional

2. METODOLOGI AUDIT

Audit ini dilakukan menggunakan pendekatan **Black-box Testing** — auditor tidak memiliki akses ke source code maupun infrastruktur internal, dan hanya berinteraksi dengan target sebagaimana attacker dari luar.

Framework yang digunakan:
• **OWASP Top 10** — standar industri untuk web application security testing
• **OWASP Testing Guide v4** — panduan teknis pengujian per kategori
• **CVSS v3.1** — Common Vulnerability Scoring System untuk penilaian risiko

Module yang dijalankan:
1. HTTP Security Headers Audit (Passive)
2. SSL/TLS Certificate Audit (Passive)
3. Sensitive File Exposure Scan (Passive)
4. CMS Detection & Version Check (Passive)
5. WordPress Plugin & Theme Scanner (Passive)
6. SQL Injection Scanner — Error, Boolean, Time-based (Active)
7. Reflected XSS Scanner (Active)
8. Stored XSS Scanner (Active)
9. CSRF Protection Checker (Active)
10. Open Port Reconnaissance (Active)

3. TEMUAN KERENTANAN

Temuan #1: Content-Security-Policy	HIGH
Deskripsi:	Mencegah XSS dan injeksi konten berbahaya
Rekomendasi:	Tambahkan header CSP yang sesuai. Minimal: Content-Security-Policy: default-src 'self'

Temuan #2: File: /phpmyadmin/	HIGH
Deskripsi:	EXPOSED! phpMyAdmin terdeteksi — akses langsung ke manajemen database (HTTP 200, 18492 bytes)
Rekomendasi:	Hapus phpMyAdmin dari production atau batasi akses via IP allowlist

Temuan #3: Plugin Outdated: WPForms Lite	HIGH
Deskripsi:	WPForms Lite v1.8.4.1 terdeteksi outdated (latest: v1.9.2). Versi lama sering punya kerentanan known.
Rekomendasi:	Update plugin WPForms Lite ke versi terbaru via WP Admin Dashboard

Temuan #4: Plugin Outdated: Contact Form 7	HIGH
Deskripsi:	Contact Form 7 v5.8.2 terdeteksi outdated (latest: v5.9). Versi lama sering punya kerentanan known.
Rekomendasi:	Update plugin Contact Form 7 ke versi terbaru via WP Admin Dashboard

Temuan #5: Plugin Outdated: Elementor	HIGH
Deskripsi:	Elementor v3.17.3 terdeteksi outdated (latest: v3.25). Versi lama sering punya kerentanan known.
Rekomendasi:	Update plugin Elementor ke versi terbaru via WP Admin Dashboard

Temuan #6: Plugin Outdated: WooCommerce	HIGH
Deskripsi:	WooCommerce v8.2.5 terdeteksi outdated (latest: v9.4). Versi lama sering punya kerentanan known.
Rekomendasi:	Update plugin WooCommerce ke versi terbaru via WP Admin Dashboard

Temuan #7: Plugin Outdated: WP Mail SMTP	HIGH
Deskripsi:	WP Mail SMTP v3.11.1 terdeteksi outdated (latest: v4.3). Versi lama sering punya kerentanan known.
Rekomendasi:	Update plugin WP Mail SMTP ke versi terbaru via WP Admin Dashboard

Temuan #8: Plugin Outdated: Polylang	HIGH
Deskripsi:	Polylang v3.5.2 terdeteksi outdated (latest: v3.6). Versi lama sering punya kerentanan known.
Rekomendasi:	Update plugin Polylang ke versi terbaru via WP Admin Dashboard

Temuan #9: Plugin Outdated: MC4WP Mailchimp	HIGH
Deskripsi:	MC4WP Mailchimp v4.9.9 terdeteksi outdated (latest: v4.10). Versi lama sering punya kerentanan known.
Rekomendasi:	Update plugin MC4WP Mailchimp ke versi terbaru via WP Admin Dashboard

Temuan #10: CSRF: POST form → /	HIGH
Deskripsi:	Form POST tanpa CSRF token — rentan terhadap CSRF attack
Rekomendasi:	Tambahkan CSRF token (hidden input) pada setiap form POST. Gunakan framework yang mendukung CSRF protection built-in (Django, Laravel, Express csrf middleware).

Temuan #11: HTTP Method: PUT	HIGH
Deskripsi:	PUT method diterima server (HTTP 200) — File upload/overwrite — attacker bisa upload webshell atau overwrite file
Rekomendasi:	Disable PUT method kecuali diperlukan untuk API (dan lindungi dengan autentikasi)

Temuan #12: HTTP Method: DELETE	HIGH
Deskripsi:	DELETE method diterima server (HTTP 200) — File deletion — attacker bisa menghapus file di server
Rekomendasi:	Disable DELETE method kecuali diperlukan untuk API

Temuan #13: Directory: /phpmyadmin	HIGH
Deskripsi:	Path /phpmyadmin accessible (HTTP 301, 240 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #14: Directory: /phpmyadmin/	HIGH
Deskripsi:	Path /phpmyadmin/ accessible (HTTP 200, 18492 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #15: X-Frame-Options	MEDIUM
Deskripsi:	Mencegah clickjacking via iframe
Rekomendasi:	Tambahkan header: X-Frame-Options: DENY atau SAMEORIGIN

Temuan #16: X-Content-Type-Options	MEDIUM
Deskripsi:	Mencegah MIME-type sniffing
Rekomendasi:	Tambahkan header: X-Content-Type-Options: nosniff

Temuan #17: Cookie: pll_language	MEDIUM
Deskripsi:	Cookie tidak aman: Missing 'HttpOnly' flag
Rekomendasi:	Set flag Secure dan HttpOnly pada semua cookie sensitif

Temuan #18: XML-RPC Endpoint	MEDIUM
Deskripsi:	xmlrpc.php aktif — bisa disalahgunakan untuk brute force dan DDoS amplification
Rekomendasi:	Disable XML-RPC jika tidak digunakan, atau batasi aksesnya

Temuan #19: Clickjacking: /	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: X-Frame-Options, CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #20: X-XSS-Protection	LOW
Deskripsi:	Mengaktifkan filter XSS bawaan browser (legacy)
Rekomendasi:	Tambahkan header: X-XSS-Protection: 1; mode=block (atau gunakan CSP sebagai pengganti)

Temuan #21: Referrer-Policy	LOW
Deskripsi:	Mengontrol informasi referrer yang dikirim browser
Rekomendasi:	Tambahkan header: Referrer-Policy: strict-origin-when-cross-origin

Temuan #22: Permissions-Policy	LOW
Deskripsi:	Mengontrol akses fitur browser (kamera, mikrofon, geolokasi)
Rekomendasi:	Tambahkan header: Permissions-Policy: geolocation=(), camera=(), microphone=()

Temuan #23: Server (Info Leak)	LOW
Deskripsi:	Terdeteksi: cloudflare — Membocorkan versi web server (misal: Apache/2.4.41)
Rekomendasi:	Sembunyikan atau hapus header Server dari response

Temuan #24: Info Disclosure: /readme.html	LOW
Deskripsi:	File '/readme.html' accessible — membocorkan informasi versi WordPress
Rekomendasi:	Blokir akses ke /readme.html via konfigurasi web server

Temuan #25: Info Disclosure: WPForms Lite readme.txt	LOW
Deskripsi:	File readme.txt plugin WPForms Lite accessible — membocorkan versi plugin
Rekomendasi:	Blokir akses ke /wp-content/plugins/wpforms-lite/readme.txt

Temuan #26: Info Disclosure: Contact Form 7 readme.txt	LOW
Deskripsi:	File readme.txt plugin Contact Form 7 accessible — membocorkan versi plugin
Rekomendasi:	Blokir akses ke /wp-content/plugins/contact-form-7/readme.txt

Temuan #27: Info Disclosure: Elementor readme.txt	LOW
Deskripsi:	File readme.txt plugin Elementor accessible — membocorkan versi plugin
Rekomendasi:	Blokir akses ke /wp-content/plugins/elementor/readme.txt

Temuan #28: Info Disclosure: WooCommerce readme.txt	LOW
Deskripsi:	File readme.txt plugin WooCommerce accessible — membocorkan versi plugin
Rekomendasi:	Blokir akses ke /wp-content/plugins/woocommerce/readme.txt

Temuan #29: Info Disclosure: Classic Editor readme.txt	LOW
Deskripsi:	File readme.txt plugin Classic Editor accessible — membocorkan versi plugin
Rekomendasi:	Blokir akses ke /wp-content/plugins/classic-editor/readme.txt

Temuan #30: Info Disclosure: Wordfence Security readme.txt	LOW
Deskripsi:	File readme.txt plugin Wordfence Security accessible — membocorkan versi plugin
Rekomendasi:	Blokir akses ke /wp-content/plugins/wordfence/readme.txt

Temuan #31: Info Disclosure: All in One SEO readme.txt	LOW
Deskripsi:	File readme.txt plugin All in One SEO accessible — membocorkan versi plugin
Rekomendasi:	Blokir akses ke /wp-content/plugins/all-in-one-seo-pack/readme.txt

Temuan #32: Info Disclosure: MonsterInsights readme.txt	LOW
Deskripsi:	File readme.txt plugin MonsterInsights accessible — membocorkan versi plugin
Rekomendasi:	Blokir akses ke /wp-content/plugins/google-analytics-for-wordpress/readme.txt

Temuan #33: Info Disclosure: WP Mail SMTP readme.txt	LOW
Deskripsi:	File readme.txt plugin WP Mail SMTP accessible — membocorkan versi plugin
Rekomendasi:	Blokir akses ke /wp-content/plugins/wp-mail-smtp/readme.txt

Temuan #34: Info Disclosure: Polylang readme.txt	LOW
Deskripsi:	File readme.txt plugin Polylang accessible — membocorkan versi plugin
Rekomendasi:	Blokir akses ke /wp-content/plugins/polylang/readme.txt

Temuan #35: Info Disclosure: MC4WP Mailchimp readme.txt	LOW
Deskripsi:	File readme.txt plugin MC4WP Mailchimp accessible — membocorkan versi plugin
Rekomendasi:	Blokir akses ke /wp-content/plugins/mailchimp-for-wp/readme.txt

Temuan #36: Info Disclosure: Theme style.css	LOW
Deskripsi:	File style.css theme accessible — membocorkan nama dan versi theme
Rekomendasi:	Blokir akses langsung ke style.css theme

Temuan #37: Cookie: pll_language	LOW
Deskripsi:	Cookie 'pll_language' memiliki 1 masalah: Missing HttpOnly flag
Rekomendasi:	Set flag: HttpOnly pada cookie 'pll_language'

Temuan #38: Directory: /admin	LOW
Deskripsi:	Path /admin accessible (HTTP 301, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #39: Directory: /admin/	LOW
Deskripsi:	Path /admin/ accessible (HTTP 301, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #40: Directory: /admin/index.php	LOW
Deskripsi:	Path /admin/index.php accessible (HTTP 301, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #41: Directory: /dashboard	LOW
Deskripsi:	Path /dashboard accessible (HTTP 302, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #42: Directory: /login	LOW
Deskripsi:	Path /login accessible (HTTP 302, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #43: Directory: /test	LOW
Deskripsi:	Path /test accessible (HTTP 301, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #44: Directory: /wp-admin	LOW
Deskripsi:	Path /wp-admin accessible (HTTP 301, 238 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #45: Directory: /wp-content/uploads	LOW
Deskripsi:	Path /wp-content/uploads accessible (HTTP 301, 248 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #46: Directory: /log	LOW
Deskripsi:	Path /log accessible (HTTP 301, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #47: Directory: /wp-login.php	LOW
Deskripsi:	Path /wp-login.php accessible (HTTP 200, 13311 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #48: Directory: /wp-json	LOW
Deskripsi:	Path /wp-json accessible (HTTP 200, 1131440 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #49: Directory: /administrator/index.php	LOW
Deskripsi:	Path /administrator/index.php accessible (HTTP 301, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #50: Directory: /readme.html	LOW
Deskripsi:	Path /readme.html accessible (HTTP 200, 7406 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #51: Directory: /robots.txt	LOW
Deskripsi:	Path /robots.txt accessible (HTTP 200, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #52: Directory: /sitemap_index.xml	LOW
Deskripsi:	Path /sitemap_index.xml accessible (HTTP 302, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #53: Directory: /sitemap.xml	LOW
Deskripsi:	Path /sitemap.xml accessible (HTTP 200, 2471 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #54: Directory: /wp-cron.php	LOW
Deskripsi:	Path /wp-cron.php accessible (HTTP 200, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #55: security.txt (missing)	LOW
Deskripsi:	security.txt tidak ditemukan — best practice adalah menyediakan file ini agar security researcher tahu cara melaporkan kerentanan
Rekomendasi:	Buat file /.well-known/security.txt sesuai RFC 9116. Minimal berisi Contact: dan Expires: fields.

4. DETAIL HASIL PER MODULE

Module 1 — HTTP Security Headers

Passed: **3** | Failed: **8** | Total: **11**

Check	Severity
Content-Security-Policy	HIGH
X-Frame-Options	MEDIUM
X-Content-Type-Options	MEDIUM
X-XSS-Protection	LOW
Referrer-Policy	LOW
Permissions-Policy	LOW
Server (Info Leak)	LOW
Cookie: pll_language	MEDIUM

Module 2 — SSL/TLS Certificate

Passed: **6** | Failed: **0** | Total: **6**

Module 3 — Sensitive File Exposure

Passed: **34** | Failed: **1** | Total: **35**

Check	Severity
File: /phpmyadmin/	HIGH

Module 4 — CMS Detection

Passed: **2** | Failed: **1** | Total: **3**

Check	Severity
Info Disclosure: /readme.html	LOW

Module 5 — WordPress Plugin Scanner

Passed: **3** | Failed: **20** | Total: **23**

Check	Severity
Plugin Outdated: WPForms Lite	HIGH
Info Disclosure: WPForms Lite readme.txt	LOW
Plugin Outdated: Contact Form 7	HIGH
Info Disclosure: Contact Form 7 readme.txt	LOW
Plugin Outdated: Elementor	HIGH
Info Disclosure: Elementor readme.txt	LOW

Plugin Outdated: WooCommerce	HIGH
Info Disclosure: WooCommerce readme.txt	LOW
Info Disclosure: Classic Editor readme.txt	LOW
Info Disclosure: Wordfence Security readme.txt	LOW
Info Disclosure: All in One SEO readme.txt	LOW
Info Disclosure: MonsterInsights readme.txt	LOW
Plugin Outdated: WP Mail SMTP	HIGH
Info Disclosure: WP Mail SMTP readme.txt	LOW
Plugin Outdated: Polylang	HIGH

Module 6 — Advanced SQL Injection

Passed: **1** | Failed: **0** | Total: **1**

Module 7 — Reflected XSS

Passed: **1** | Failed: **0** | Total: **1**

Module 8 — Stored XSS

Passed: **1** | Failed: **0** | Total: **1**

Module 9 — CSRF Protection

Passed: **2** | Failed: **1** | Total: **3**

Check	Severity
CSRF: POST form → /	HIGH

Module 10 — Port Reconnaissance

Passed: **4** | Failed: **0** | Total: **4**

5. KESIMPULAN DAN SARAN PRIORITAS

Berdasarkan hasil audit, website **polmed.ac.id** memiliki **0 kerentanan CRITICAL** dan **14 kerentanan HIGH** yang memerlukan perhatian segera.

Saran prioritas perbaikan:

1. [HIGH] Content-Security-Policy
Tambahkan header CSP yang sesuai. Minimal: Content-Security-Policy: default-src 'self'

2. [HIGH] File: /phpmyadmin/
Hapus phpMyAdmin dari production atau batasi akses via IP allowlist

3. [HIGH] Plugin Outdated: WPForms Lite
Update plugin WPForms Lite ke versi terbaru via WP Admin Dashboard

4. [HIGH] Plugin Outdated: Contact Form 7
Update plugin Contact Form 7 ke versi terbaru via WP Admin Dashboard

5. [HIGH] Plugin Outdated: Elementor
Update plugin Elementor ke versi terbaru via WP Admin Dashboard

DISCLAIMER

Laporan ini dihasilkan secara otomatis oleh Spencer Web Security Audit Tool. Audit dilakukan pada waktu dan kondisi tertentu; kondisi keamanan website dapat berubah seiring waktu. Hasil audit ini hanya mencakup parameter yang diuji oleh tool dan tidak menggantikan audit keamanan manual oleh professional security expert. Beberapa temuan automated scanner dapat berupa false positive dan harus diverifikasi secara manual sebelum tindakan perbaikan diambil.

Generated by Spencer v2.0 — 21 May 2026